



GOVTELLIGENCE

AI Governance & Compliance

AI Governance Landscape

2025 – 2026

A Board-Oriented Synthesis of Enterprise Compliance,
Auditability & Assurance

GOVERNANCE REFERENCE FRAMEWORK · INSTITUTIONAL USE



GOVTELLIGENCE

AI Governance & Compliance · govtelligence.com

Not legal advice. For institutional use only.



CONTENTS

Table of Contents

00	Executive Summary	3
	Key findings, governance shift, framework overview	
01	The Regulatory Landscape	4
	EU AI Act · NIST RMF · ISO 42001 · UK · US · OECD	
02	Algorithmic Auditing	6
	Internal, external & regulatory audit frameworks	
03	Data Lineage & Provenance	7
	Copyright exposure · GDPR erasure · lineage systems	
04	Shadow AI & Enterprise Exposure	8
	Insider-threat surface · DLP · acceptable-use gaps	
05	Board-Level Fiduciary Duty	9
	Caremark doctrine · assurance packages · insurance	
06	Research Gaps & Open Problems	10
	Fragmentation · temporal drift · agentic systems	
—	Governance Framework Summary	11
	Three-pillar synthesis · control stack overview	
—	References & Bibliography	12
	Full citation list · APA format	

Page numbers are set during document compilation. All section cross-references reflect the final paginated output.



00 / OVERVIEW

Executive Summary

The dominant governance pattern in 2025–2026 marks a decisive shift from high-level ethics principles toward operational controls: risk classification, documentation, testing, monitoring, incident reporting, and post-deployment accountability. The EU AI Act represents the most prescriptive binding regime globally, while NIST AI RMF and ISO/IEC 42001 provide the main implementation scaffolding used by enterprises across jurisdictions.

The central unresolved issue is not whether governance matters, but how to standardize AI assurance in a way that is technically robust, legally interoperable, and auditable at scale. Fragmentation — across jurisdictions, frameworks, and technical disciplines — remains the defining challenge for boards and compliance functions in 2025.

KEY FINDINGS

EU AI Act

A risk-tier model with prohibitions, high-risk obligations, and specific transparency duties for limited-risk systems, plus layered obligations for GPAI and systemic-risk GPAI providers that extend to adversarial testing and incident reporting.

NIST AI RMF 1.0

The primary US implementation framework — a structured, voluntary risk-management playbook organized around Govern, Map, Measure, and Manage. Enterprises typically pair it with ISO/IEC 42001 to achieve external auditability.

ISO/IEC 42001:2023

The first certifiable AI management-system standard, analogous in structure to ISO 27001. Provides the external assurance layer that converts internal governance practice into independently verifiable compliance evidence.

Jurisdictional Fragmentation

A company can be fully NIST-aligned yet still lack EU-grade technical documentation, or ISO-certified yet miss region-specific incident-reporting requirements. Harmonization is improving but materially incomplete.

01 / REGULATION

The Regulatory Landscape

The regulatory environment for AI has entered a phase of binding obligations alongside voluntary frameworks. Enterprises face a multi-layered compliance challenge spanning geographic jurisdictions, sectors, and system types. Understanding the interplay between these regimes is the foundational board-level task.

EU AI Act

The EU AI Act is a binding, risk-based framework organizing AI systems into four categories: prohibited, high-risk, limited-risk, and minimal-risk. Compliance for high-risk systems requires a lifecycle risk-management system, data governance protocols, technical documentation, logging capabilities, human oversight mechanisms, and post-market monitoring. For GPAI and systemic-risk GPAI providers, obligations extend to model evaluations, adversarial testing, systemic-risk mitigation, incident reporting, and enhanced cybersecurity controls.

The enforcement timeline is progressive. High-risk and GPAI-related obligations phase in earlier than the full applicability date of 2 August 2027, requiring enterprises to maintain a dated obligations matrix rather than a single go-live compliance plan.

GOVERNANCE IMPLICATION

Required documentation set: conformity file, technical documentation, risk-management records, test and evaluation results, post-market monitoring logs, incident reports, and human-oversight procedures. A phased obligations calendar is essential.

NIST AI RMF 1.0

NIST AI RMF 1.0 organizes AI risk management around four core functions. Govern covers policies, accountability, organizational culture, stakeholder engagement, and third-party risk. Map defines context, intended use, and AI system interactions. Measure evaluates risks using quantitative and qualitative methods. Manage selects controls, tracks residual risk, and links incidents to remediation pathways.

Because NIST is voluntary, enterprises typically pair it with sectoral rules or ISO/IEC 42001 to achieve external auditability. Core documentation includes: AI system inventory, risk taxonomy, evaluation plans, controls mapping, and residual-risk acceptance records.

FRAMEWORK COMPARISON

Framework	Type	Scope	Key Deliverables
EU AI Act	Binding Law	EU market + global reach	Conformity file, tech docs, post-market monitoring, incident reports
NIST AI RMF 1.0	Voluntary	US (global adoption)	Risk register, eval results, controls map, incident logs
ISO/IEC 42001	Certifiable Standard	Global	Management system evidence pack, internal audit results
UK AI Security Inst. Principles-based	UK (frontier focus)		Red-team reports, safety-case summaries, supplier assurances
US EO 14110	Federal Policy	US regulated sectors	Model cards, evaluation results, cybersecurity artifacts
OECD / G7 Hiroshima Soft Law		G7 nations	Governance narrative, safety testing disclosure

Singapore MAS / APAC

Financial services + AI model validation reports, outsourcing due diligence

ISO/IEC 42001:2023

ISO/IEC 42001:2023 is the first AI management-system standard, designed to help organizations establish, implement, maintain, and continually improve an AI management system. Structured like other ISO management standards — with leadership, planning, support, operations, performance evaluation, and improvement — it includes AI-specific controls and implementation guidance in dedicated annexes.

GOVERNANCE IMPLICATION

Required evidence pack: scope statement, AI policy, risk assessment, control objectives, operational procedures, internal audit results, management review minutes, corrective actions, and continual-improvement records. ISO 42001 demonstrates due diligence and operational maturity but does not replace legal obligations under binding regimes.

UK, US & International Frameworks

The UK's approach remains principles-based and sector-led. The AI Security Institute (renamed from AISI in 2025) focuses on model evaluation, frontier-model risk, and misuse, with voluntary safety commitments creating documentation expectations around red-teaming and supplier assurances rather than a hard compliance code.

US obligations under Executive Order 14110 remain fragmented across agencies and sectors. Companies selling to government or operating in regulated sectors face documentation demands around safety testing, incident response, cybersecurity, and procurement disclosures. The OECD Principles and G7 Hiroshima Process add voluntary disclosure obligations for frontier model developers. APAC frameworks — Singapore MAS model risk management, Japan's soft-law coordination — require jurisdiction-by-jurisdiction control mapping rather than a single universal standard.

02 / AUDITING

Algorithmic Auditing & Model Validation

Academic and regulatory literature distinguishes three assurance models: internal audit (conducted by the operating organization), external audit (independent third parties), and regulatory audit (public authorities or quasi-regulators). Algorithmic auditing is broader than model testing alone — encompassing governance, process, data, and organizational controls throughout the AI lifecycle.

LAYERED AUDIT METHODOLOGY

The most defensible enterprise methodology proceeds in structured stages: inventory the system; define the decision context and intended use; test outcomes and potential harms; probe the model and underlying data; assess governance structures; and record remediation actions with accountability assignments. This layered approach creates an evidence chain defensible under both regulatory scrutiny and litigation.

RESEARCH GAP

AUDIT STANDARDIZATION

No universally accepted audit methodology analogous to financial GAAP exists for AI assurance. Current work is fragmented between regulatory studies, technical benchmarking, and management-system standards — creating an interoperability gap between what technical researchers measure and what enterprises can operationalize at scale.

DRIFT DETECTION & MODEL MONITORING

The literature supports PSI (Population Stability Index), KS tests, ADWIN, and DDM as well-established drift detection techniques. No single universal threshold applies across domains — alert frequencies are calibrated to business criticality and data velocity. The enterprise norm is continuous monitoring for high-impact models and periodic revalidation for lower-risk systems, with warning and drift bands set against baseline performance metrics.

GOVERNANCE IMPLICATION

Required documentation: drift monitoring dashboards, revalidation schedules, alert threshold justifications, and remediation logs linked to model version control. Failure thresholds should be model- and context-specific, not universal.

03 / DATA

Data Lineage & Provenance

Automated lineage systems — including W3C PROV, OpenLineage, and Apache Atlas — form the backbone for reproducibility, governance, and incident response. Enterprise lineage maturity is highest in data-platform-heavy organizations and weakest where models depend on external APIs or unstructured web and RAG sources.

Copyright & IP Exposure

Key litigation — Getty Images v. Stability AI, New York Times v. OpenAI, and Authors Guild-related disputes — has elevated training-data provenance to a fiduciary issue, not merely a legal one. Organizations need documented evidence of data sourcing, licensing status, exclusion procedures, and takedown/erasure workflows.

Where training data rights are uncertain, boards should treat the exposure as a contingent liability and an operational controls matter requiring disclosure to auditors and, where material, to investors.

GOVERNANCE IMPLICATION

Required documentation: lineage graphs, dataset version histories, provenance metadata, licensing records, change logs, consent posture mapping, and documented erasure/retraining procedures. Unresolved training data rights should be reported as contingent liabilities.

GDPR Erasure & ML Training Data

A persistent compliance tension exists because models can embed training data in ways that are difficult to delete with precision. Documented penalties arise more commonly from broader GDPR failures than from AI-specific deletion precedents. Governance best practice is to maintain consent posture mapping, provenance records, and documented retraining/forgetting procedures, even where specific AI erasure case law remains limited.

RESEARCH GAP

ERASURE PRECEDENT

Peer-reviewed evidence on AI-specific GDPR deletion penalties remains thin. The compliance burden is currently defined more by regulatory expectations and practitioner consensus than by settled case law. Boards should treat this as an evolving obligation requiring proactive posture mapping.

04 / SHADOW AI

Shadow AI & Enterprise Exposure

The evidence base on shadow AI is growing rapidly but remains survey-driven, largely from consulting, vendor, and industry reports rather than peer-reviewed longitudinal studies. The consistent pattern across organizations: employees adopt consumer AI tools before formal approval processes can respond, creating data leakage, privacy, and IP risks — particularly where prompts contain confidential or regulated information.

The Insider-Threat Surface

The Samsung incident — widely cited as a case where employees pasted sensitive source code into a public AI tool — demonstrates the exfiltration risk of unmanaged AI usage at scale. CISA and NIST-style guidance treats LLM integrations as materially expanding the insider-threat surface because the model can move data, automate actions, and route information to external systems with minimal friction.

ENTERPRISE CONTROL SET

Approved-Tool Registry — Maintain a formally approved AI tool list with access controls, version management, and periodic security review. Treat unapproved tools as a data handling violation.

Data Loss Prevention (DLP) — Configure DLP to detect and block AI-specific exfiltration patterns, including prompt injection attempts and bulk pasting of classified content.

Prompt Logging & Audit — Log AI interactions for regulated data detection, incident response, and audit readiness. Retention periods should align with applicable data governance policies.

Data Classification Rules — Classify data before it reaches any AI interface. Prohibit confidential, regulated, or client data from entering unapproved tools; automate detection where possible.

Vendor Restrictions — Conduct AI-specific third-party risk assessments. Contractually restrict vendors from training on customer inputs and require incident notification SLAs.

Acceptable-Use Policy — Publish and enforce a clear AI acceptable-use policy. The absence of a published policy is itself a material control gap — shadow AI grows fastest in policy vacuums.

05 / FIDUCIARY

Board-Level Fiduciary Duty

Board fiduciary duty over AI risk is analyzed through Delaware oversight doctrine — in particular the Caremark-style duties requiring good-faith oversight systems and reporting channels sufficient to surface material risks. While AI-specific fiduciary case law remains limited, the governance logic is well established: boards must supervise material operational risks, and AI becomes material when it affects legal compliance, safety, reputation, or financial reporting.

The absence of AI-specific derivative precedent does not eliminate exposure — it means the analogies are still being constructed through doctrine and enforcement practice. Boards that lack documented AI oversight mechanisms face increasing scrutiny from investors, regulators, and insurers.

BOARD-READY AI ASSURANCE PACKAGE

- AI system inventory with materiality and risk ranking
- Policy and controls map aligned to applicable regulatory frameworks
- Model validation summaries and drift monitoring status reports
- Incident and escalation logs with remediation tracking and closure evidence
- Third-party and vendor AI risk reviews with contractual controls evidence
- Legal and regulatory obligations register with dated compliance milestones
- Disclosure controls and governance statement alignment (public companies)
- Insurance underwriting posture review — cyber, professional liability, media/IP

"The absence of AI-specific derivative precedent does not eliminate fiduciary exposure — it means the analogies are still being built through doctrine and enforcement practice."

GOVERNANCE IMPLICATION

For public companies: align assurance packages to disclosure controls and risk-factor quality statements. Investors increasingly expect AI risk-factor specificity comparable to cybersecurity and climate disclosures. Insurance markets now treat AI governance as an underwriting question — weak controls increase both direct loss exposure and insurability friction.

06 / RESEARCH GAPS

Open Problems & Research Gaps

The literature repeatedly flags fragmentation as the core unresolved issue: the governance architecture is broadening faster than it is standardizing. The gaps below represent areas where practitioner consensus is currently doing more work than peer-reviewed evidence — a distinction that matters for board-level risk assessment.

RESEARCH GAP

NO UNIVERSAL AUDIT STANDARD

No audit methodology analogous to GAAP exists for AI assurance. Work is fragmented between regulatory studies, technical benchmarking, and management-system standards — creating an interoperability gap between what researchers measure and what enterprises can operationalize.

RESEARCH GAP

TEMPORAL GENERALIZATION

A major unsolved problem in explainability and validation: models evaluated in one period and deployed in another exhibit unpredictable temporal drift. Current frameworks were largely designed for static model deployments, not adaptive or continually-updated systems.

RESEARCH GAP

AGENTIC & MULTIMODAL SYSTEMS

LLM bias, hallucination, and robustness risks are better studied at the model level than inside governed enterprise workflows. Agentic and multimodal systems are especially under-addressed — most current frameworks assume static deployments rather than tool-using, multi-step, adaptive architectures.

RESEARCH GAP

JURISDICTIONAL FRAGMENTATION

A company can be NIST-aligned yet lack EU-grade technical documentation, or ISO-certified yet miss region-specific incident-reporting requirements. Harmonization across EU, US, UK, and APAC is improving but materially incomplete.

RESEARCH GAP

ENTERPRISE VALIDATION STATISTICS

Precise percentages on formal model validation coverage, Fortune 500 AI policy adoption, and shadow-AI prevalence should be treated as practitioner estimates, not scientific findings. The absence of standardized reporting makes cross-industry benchmarking unreliable.



SYNTHESIS

Govtelligence Governance Framework

The most mature operating pattern today combines EU-style lifecycle documentation, NIST-style risk management, and ISO-style management-system assurance into a single unified governance architecture. The immediate board priority is a control stack that can map obligations across jurisdictions, evidence system risk, and produce audit-ready documentation continuously — not only at audit time.

PILLAR	PRIMARY FRAMEWORK	ENTERPRISE OUTPUT
Lifecycle Documentation	EU AI Act	Conformity file · Technical documentation · Post-market logs · Incident reports
Risk Management	NIST AI RMF 1.0	Risk register · Controls map · Residual-risk acceptance · Monitoring dashboard
Management System Assurance	ISO/IEC 42001:2023	Audit evidence pack · Internal audit results · Continual-improvement records
Sectoral Compliance	MAS · FCA · Sector rules	Use-case registers · Model validation reports · Outsourcing due diligence
Voluntary & International	OECD · G7 Hiroshima	Reporting-ready governance narrative · Safety testing disclosures

ABOUT & ENGAGEMENT

Request a Board Briefing

Govtelligence provides board-ready AI governance frameworks, compliance readiness assessments, and institutional briefings. Our synthesis work draws on current regulatory developments, practitioner evidence, and independent analysis to equip boards with the operational intelligence required for effective AI oversight.

To request a bespoke board briefing, gap assessment, or governance review: govtelligence.com

REFERENCES & BIBLIOGRAPHY

Sources & Citations

Sources are listed in order of relevance to the sections of this report. Claims with the thinnest peer-reviewed basis — including precise enterprise percentages on formal validation coverage and shadow-AI prevalence — are noted as practitioner estimates throughout the text.

REGULATORY FRAMEWORKS

- [1] National Institute of Standards and Technology. (2022). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST.
- [2] National Institute of Standards and Technology. (2022). NIST AI RMF Playbook. NIST.
- [3] EU Artificial Intelligence Act. (2024). High-level summary of the AI Act. European Commission.
- [4] European Commission. (2025). Timeline for the Implementation of the EU AI Act. European Commission.
- [5] BSI. (2023). ISO 42001 — AI Management System. British Standards Institution.
- [6] Microsoft Compliance. (2026). ISO/IEC 42001:2023 Artificial intelligence management system. Microsoft.
- [7] Bulletproof. (2025). ISO 42001:2023 Certification for Ethical AI Governance. Bulletproof Ltd.

ALGORITHMIC AUDITING

- [8] Digital Regulation Cooperation Forum. (2022). Auditing algorithms: the existing landscape, role of regulators. DRCF.
- [9] Royal Society Open Science. (2024). Towards algorithm auditing: managing legal, ethical and technical concerns.
- [10] Lyon, A., et al. (2021). The algorithm audit: Scoring the algorithms that score us. Social Science & Medicine.
- [11] Inter-American Development Bank. (n.d.). Algorithmic Audit for Decision-Making or Decision Support Systems. IDB.
- [12] European Commission JRC. (2025). Auditing the Algorithms: New JRC review categorises risk. Joint Research Centre.

DATA LINEAGE, PROVENANCE & DRIFT

- [13] Study on concept drift detection algorithms for real-world data. (2024).
- [14] Remediating data drifts and re-establishing ML models. (2023).
- [15] Bias in Large Language Models: Origin, Evaluation, and Mitigation. (2026, preprint).
- [16] LLM hallucination and bias detection in regulated enterprise systems. (2026, preprint).
- [17] Concept Drift Detection in Document Classification. (2024).

INTERNATIONAL & SOFT-LAW FRAMEWORKS

- [18] OECD. (2025). Launch of the Hiroshima AI Process (HAIP) Reporting Framework. OECD Publishing.
- [19] OECD. (2023). G7 Hiroshima Process on Generative Artificial Intelligence (AI). OECD Publishing.
- [20] G7 Digital and Tech Ministers' Statement. (2023).
- [21] Ada Lovelace Institute. (2025). Will the UK AI Bill protect people and society?
- [22] Nemko Digital. (2025). UK AI Regulation 2025: Pro-Innovation, Safe & Smart Approach.
- [23] AI Security Institute. (2025). Our 2025 year in review. AISI/DSIT.
- [24] CIGI. (n.d.). Standards as a basis for global governance of AI in research. Centre for International Governance Innovation.

GOVERNANCE, TRUST & RESEARCH

- [25] Nature. (2024). AI governance in a complex regulatory environment. Nature Publishing Group.
- [26] KPMG International & University of Melbourne. (2025). Trust, attitudes and use of artificial intelligence. KPMG.



[27] OUP. (2025). The Global AI Governance Architecture: Past and Futures. Oxford University Press.

[28] Liminal AI. (2025). AI governance guide. Liminal AI.

This document is prepared for institutional and board-level use. It is not legal advice. Govtelligence makes no warranty regarding the completeness or accuracy of referenced third-party sources. © 2025 Govtelligence. AI Governance & Compliance.